

IR Triage Report

Front Matter

ANALYST NAME: Zachary Lopater

DATE: 04/09/2026

SOURCE: security@0x2asec.com

ALERT ID: UR-INT-20250603-0047

SEVERITY: HIGH ▾

DISPOSITION: True Positive (TP) ▾

Initial Findings

The alerting activity identified a confirmed multi-stage security incident involving an initial brute-force attack against the public-facing web server followed by a ransomware infection within the internal network. Investigation revealed successful compromise of an administrative account on *imreallynotbatman.com*, enabling unauthorized file uploads, as well as a subsequent Cerber ransomware infection originating from a single internal workstation and spreading to a file server. The scope of the incident includes the public web server, one non-privileged user workstation, an internal file server, and a compromised high-privileged account, with potential risk to additional systems due to credential exposure and lateral movement. The activity was confirmed as malicious and aligned with known attack techniques, and the incident was dispositioned as a True Positive with high confidence and assessed as High severity due to credential compromise, internal propagation, and data encryption.

Incident Summary

Overview:

Two related security incidents were identified involving a brute-force attack against a public-facing web server and a subsequent ransomware infection within the internal network. The first incident resulted in the compromise of administrative credentials and unauthorized file uploads to the web server. The second incident involved a Cerber ransomware infection originating from a user workstation, leading to lateral movement and file encryption on internal file servers. Together, these events indicate a broader compromise with both external and internal impact.

Timeline of Events (UTC)

Attack #1: Brute Force / Web Server Compromise (August 10, 2016)

- **21:45:21** – Initial brute-force login attempts observed from external IP 23.22.63.114 targeting WordPress login portal (*wp-login.php*)
- **21:46:33** – Successful authentication using administrative credentials
- **21:48:05** – Second successful login using administrative credentials
- **21:56:18** – First upload of suspicious file: *poisonivy-is-coming-for-you-batman.jpeg*
- **21:58:23** – Second upload of suspicious file
- **22:08:13** – Third upload of suspicious file
- **22:21:58** – Session terminated

Attack #2: Ransomware Infection / Internal Network Impact (August 24, 2016)

- **16:42:17** – USB device *MIRANDA_PRI* inserted into workstation **192.168.250.100 (we8105desk)**
- **16:43:21** – Malicious VBS script associated with Cerber ransomware introduced to the workstation
- **16:48:12** – Connection to suspicious domain *solidaritedeproximitye.org* observed
- **16:48:13** – Malicious file *mhtr.jpg* transferred to file server **192.168.250.20 (we9041srv)**
- **16:48:21** – Ransomware payload (*121214.tmp*) executed on file server
- **16:49:25** – Initial IDS/Suricata alert triggered, confirming malicious activity

Scope of Impact

- **Systems Affected:**
 - Public-facing web server (*imreallynotbatman.com*)
 - Internal workstation (**we8105desk – 192.168.250.100**)
 - Internal file server (**192.168.250.20**)
- **Accounts Affected:**
 - One **administrative (high-privileged) account** compromised during brute-force attack
- **Data Impact:**
 - **257 files encrypted** on internal file server due to Cerber ransomware infection
- **Extended Risk:**
 - Exposure of administrative credentials presents risk to **additional systems via credential reuse**
 - Internal network compromise demonstrates **lateral movement capability**

Impact Assessment

- **Confirmed Impacts:**
 - Unauthorized administrative access to web server
 - Malicious file uploads indicating defacement capability
 - Execution and spread of Cerber ransomware within internal network
 - Encryption of 257 files on file server
- **Potential Impacts:**
 - Data exposure and loss of availability due to encryption
 - Reputational damage from potential web defacement
 - Further compromise of internal systems via credential reuse or persistence mechanisms

MITRE ATT&CK TTPs

- **T1110 – Brute Force**
- **T1078 – Valid Accounts**
- **T1505.003 – Web Shell / Web Content Manipulation**
- **T1204 – User Execution** (USB-based infection vector)
- **T1059.005 – Command and Scripting Interpreter: Visual Basic** (VBS execution)
- **T1486 – Data Encrypted for Impact** (Cerber ransomware)
- **T1021 – Lateral Movement**

Recommended Actions

Prioritization Summary

- **High ROI / Immediate:** System isolation, credential resets, MFA, backup restoration, brute-force protections
- **Mid-Term:** Network segmentation, EDR deployment, PAM implementation

- **Long-Term:** Policy enforcement, user training, continuous SOC tuning

1. Incident Response Actions (Immediate – High Priority)

Owner: SOC / Incident Response Team / IT Operations

- **Isolate impacted systems:**
 - Remove **we8105desk (192.168.250.100)** and **file server (192.168.250.20)** from the network to prevent further ransomware spread.
- **Disable and reset compromised credentials:**
 - Immediately disable the compromised **administrative account** and enforce password resets across all privileged accounts.
- **Contain web server compromise:**
 - Remove all unauthorized files (e.g., *poisonivy-is-coming-for-you-batman.jpeg*) and validate integrity of the web server.
- **Eradicate ransomware artifacts:**
 - Identify and remove Cerber-related files (e.g., VBS scripts, *.tmp payloads*) from all affected systems.
- **Initiate recovery procedures:**
 - Restore encrypted files from **known-good backups** where available.
- **Preserve forensic evidence:**
 - Collect relevant logs (authentication, web server, endpoint, IDS) and disk/memory images for further analysis.

2. Prevention – Infrastructure Hardening (High Priority)

Owner: IT / Security Engineering

- **Implement Multi-Factor Authentication (MFA):**
 - Enforce MFA on all **administrative and remote access portals**, especially web-facing authentication systems.
- **Restrict brute-force attempts:**
 - Apply **account lockout policies**, rate limiting, and CAPTCHA on login portals (*wp-login.php*).
- **Network segmentation:**
 - Separate user workstations from critical servers to limit **lateral movement**.
- **Disable unauthorized USB usage:**
 - Enforce endpoint controls to **block or restrict removable media**.
- **Patch and harden systems:**
 - Ensure web servers, endpoints, and internal servers are **fully patched and hardened**.
- **Application allowlisting:**
 - Prevent execution of unauthorized scripts (e.g., VBS files) on endpoints and servers.

3. Prevention – Policy & Process Improvements (Medium Priority)

Owner: Security Leadership / IT Management

- **Password policy enforcement:**
 - Require **strong, unique passwords** and prohibit credential reuse across systems.
- **Privileged access management (PAM):**
 - Limit and monitor use of administrative accounts; adopt **least privilege principles**.
- **Security awareness training:**
 - Educate users on risks of **unknown USB devices** and social engineering tactics.
- **Backup policy validation:**
 - Ensure regular, tested, and **offline backups** are maintained to support ransomware recovery.

- **Access control reviews:**
 - Periodically audit user and admin account permissions.

4. Detection & SOC Improvements (Medium Priority)

Owner: SOC / Security Engineering

- **Enhance brute-force detection:**
 - Tune alerts for **repeated failed logins** and anomalous authentication patterns.
- **Monitor privileged account usage:**
 - Implement alerting for **unusual admin logins**, especially from external IPs.
- **File integrity monitoring (FIM):**
 - Detect unauthorized file uploads or modifications on web servers.
- **Endpoint detection and response (EDR):**
 - Deploy or enhance EDR to identify **script execution and ransomware behavior**.
- **Network monitoring improvements:**
 - Strengthen IDS/IPS rules to detect **malicious domains and lateral movement activity**.
- **Log centralization (SIEM):**
 - Ensure logs from web servers, endpoints, and network devices are **ingested and correlated** for faster detection.